Risk Assessment Methodology

A-01 | MapleBridge Financial Technology Inc. | v1.0 | Issued 05 November 2026

SIMULATED — FICTIONAL DATA — NOT FROM A LIVE SYSTEM

1. Document control and purpose

Field	Definition
Document ID	A-01 / RISK-METH-001
Version / status	1.0 / proposed methodology for portfolio execution; no organizational sign-off claimed
Method owner	ST-06 Compliance Lead (fictional); challenge by ST-03 Head of Security
Approver	ST-01 CEO for risk appetite and material acceptance (fictional approval required; not obtained)
Assessment window	2026-09-01 to 2026-10-31; baseline BASE-20260930; remediation REM-20261015; retest RET-20261030
Inputs	F-01 scenario, F-02 governance/RACI, F-03 architecture/assets, F-04 ID/evidence rules, F-05 framework sources, F-06 synthetic evidence

Purpose: apply a consistent, reproducible, explainable assessment of plausible cybersecurity, technology, operational resilience, data protection and third-party risks to the fictional non-bank B2B payment-instruction and reconciliation business. The methodology prioritizes management decisions; it does not establish regulatory compliance, audit assurance or objective loss probabilities.

2. Scope, boundaries and assumptions

In scope: BridgeAPI, MatchLedger, OpsConsole; MapleBridge-managed GCP Toronto workloads and Montréal recovery, PostgreSQL and object storage; Okta and Google Workspace; GitHub/Jira changes; identity lifecycle, privileged access, logging, backup/recovery, incident response, privacy safeguards, CedarPay interface and vendor governance. Risk scenarios must link to canonical RSK-### plus affected AST/SYS/DF/TB/DC IDs when applicable.

Out of scope: funds custody, settlement execution, customer-controlled systems, CedarPay internal production operations, partner-bank networks, lending, FX, remittances, cardholder-data environments, live penetration testing, statutory legal determination and independent certification/attestation. Vendor exposure at the CedarPay interface remains in scope, not the vendor's internal control testing.

Assumptions: 85 fictional staff, 120 fictional Canadian B2B customers and 1.8 million fictional monthly payment instructions; primary GCP Toronto, recovery Montréal; non-bank payment service provider. RPAA/Bank of Canada and PIPEDA are legal applicability considerations requiring

separate analysis; SOC 2, ISO 27001, NIST CSF and OSFI B-13 are not treated as certifications or automatically binding obligations. All evidence and walkthroughs are synthetic.

3. Risk taxonomy and ownership

Category	Illustrative exposure	Accountable first-line owner
Identity & access	Terminated account enabled; privileged MFA gap	ST-04 IT Lead
Cloud / infrastructure	Publicly accessible object storage; insecure workload setting	ST-08 Engineering Lead
Application & change	Unreviewed production change affecting payment API	ST-02 CTO (with ST-05 Product Lead)
Availability & recovery	BridgeAPI outage; failed recovery test	ST-02 CTO
Data protection & privacy	Customer payment metadata exposed or retained improperly	ST-05 Product Lead
Third-party / concentration	CedarPay interface disruption or assurance gap	ST-07 Vendor Owner
Monitoring & response	Material alert not detected or escalated	ST-03 Head of Security
Regulatory / contractual	Potential reporting, safeguarding or contractual gap	ST-06 Compliance Lead

Each RSK record has exactly one accountable risk owner (ST-01–ST-08; ST-09 assessor cannot own or accept management risk), plus affected systems, scenario, exposure, treatment and due date. Compliance Lead is accountable for maintaining the risk register; Head of Security challenges scoring; CEO sets appetite and approves material residual risk acceptance. CTO owns technology remediation; the portfolio assessor records simulated analysis only.

4. Assessment workflow

1. Identify a concrete threat/event, vulnerability or failure mode, affected asset/data flow, business objective, existing controls and plausible consequence; record a causal scenario, not just a control failure.

2. Determine inherent likelihood (L, 1–5) and inherent impact (I, 1–5) assuming relevant mitigating controls are absent or ineffective; retain underlying operating context and inherent exposure assumptions.

3. Identify controls and evaluate design and operating evidence by snapshot. Record effectiveness as Effective, Partially effective, Ineffective or Not evaluated with rationale and evidence IDs.

4. Determine residual L and I after only demonstrably operating controls. Do not reduce a score solely because a policy or remediation ticket exists. If evidence is insufficient, mark provisional/unknown and do not assert a low residual risk.

5. Compute score = L × I, map to the fixed band and compare with proposed risk appetite. Document rationale, alternatives, uncertainty, treatment, owner, target date and reviewer challenge.

6. Reassess at remediation/retest snapshots or on material change; preserve original baseline scores and maintain an append-only scoring history. Closure requires evidence and, when applicable, passing retest and approval.

5. Likelihood criteria — 12-month scenario horizon

Likelihood measures the reasoned chance of the defined scenario occurring at least once in the next 12 months, not frequency of an existing control failure. Descriptors are qualitative; numeric probabilities are deliberately not assigned because synthetic evidence cannot calibrate them.

L	Label	Decision criteria / concrete example
1	Rare	Exceptional event requiring several unlikely independent conditions; e.g., simultaneous failure of geographically separated recovery dependencies with credible resilience evidence.
2	Unlikely	Plausible but unusual given exposure and reliable safeguards; e.g., a narrowly exposed privileged workflow with tested MFA and review.
3	Possible	Credible event in normal operating conditions; e.g., intermittent CedarPay interface disruption with some mitigations but uncertain recovery.
4	Likely	Repeated weaknesses or substantial exposure make event reasonably expected; e.g., privileged access lacks enforced MFA and is regularly used.
5	Almost certain	Ongoing/recurrent event or near-inevitable scenario within horizon; e.g., repeated unresolved production service failures with persistent triggering conditions.

Scoring guidance: use incident/exception frequency, exposure, threat opportunity, system criticality, control performance and time at risk; distinguish direct observations from assumptions. A single synthetic exception does not automatically imply L=5.

6. Impact criteria — highest credible dimension governs

Evaluate customer harm, availability, direct financial loss, regulatory/contractual consequences and reputation separately; select the highest defensible dimension as overall I. Financial thresholds are

hypothetical internal portfolio calibration points in CAD, not actual loss history, legal thresholds or an approved appetite.

I	Customer harm	Service outage	Financial loss (CAD)	Compliance / reputation
1	Negligible; no customer-facing disruption	<15 min; no critical workflow	<5,000	Internal correction; no reportable event; negligible external notice
2	Minor inconvenience; small customer subset	15 min–<2 h; limited degradation	5,000–<25,000	Minor contractual issue; limited customer concern
3	Material disruption to several customers; recoverable impact	2–<8 h of critical workflow impairment	25,000–<100,000	Potential material contractual/privacy review; sustained customer complaints
4	Severe harm to many customers or sensitive metadata exposure	8–<24 h critical workflow outage	100,000–<500,000	Credible serious regulatory/contractual consequence; widespread adverse coverage
5	Widespread or prolonged severe harm; potentially irreversible exposure	≥24 h critical workflow outage or recovery failure	≥500,000	Potential major enforcement/litigation exposure; lasting loss of customer trust

I	Reputation-specific anchor
1	No meaningful external awareness; routine internal correction
2	Isolated customer concern; quickly resolved
3	Multiple customer complaints or limited negative industry attention
4	Widespread adverse coverage and meaningful customer confidence loss
5	Sustained national attention, major churn or enduring trust damage

If dimensions conflict, record all five and explain the selected maximum. The regulatory dimension is an impact hypothesis, not a legal conclusion. A near miss may have low realized harm but high plausible impact; score the defined future scenario consistently.

7. Matrix, rating and decision rules

Score = likelihood (1–5) × impact (1–5); no rounding. Fixed bands: Low 1–4; Moderate 5–9; High 10–16; Critical 17–25. The 5×5 grid below lists score / rating. These bands are portfolio methodology choices, not externally mandated standards.

L \ I	1	2	3	4	5
1	1/L	2/L	3/L	4/L	5/M
2	2/L	4/L	6/M	8/M	10/H
3	3/L	6/M	9/M	12/H	15/H
4	4/L	8/M	12/H	16/H	20/C
5	5/M	10/H	15/H	20/C	25/C

Band	Management response / proposed target (not approved appetite)
Low (1–4)	Track in register; owner review at scheduled quarterly cycle.
Moderate (5–9)	Owner treatment plan or documented rationale; review within 60 days.
High (10–16)	Escalate to CTO / Compliance Lead and CEO; target treatment decision within 30 days; monitor monthly.
Critical (17–25)	Immediate executive escalation; urgent containment decision, target within 5 business days; monitor until reduced.

No automatic risk acceptance: proposed review windows are portfolio planning defaults only. CEO approval is required for material residual risk acceptance under F-02; no approval is represented as already granted. Critical risks require immediate escalation irrespective of score arithmetic. A credible catastrophic I=5 scenario may be escalated even if its numerical band is Moderate.

8. Evidence standard and reproducibility

Every scored risk record must include: risk_id; title; cause-event-consequence statement; category; owner_id; linked asset/system IDs; scenario horizon; snapshot_id; inherent L/I/score/band; five impact dimensions; control IDs and effectiveness; residual L/I/score/band or Unknown; evidence IDs and paths; source hash/verification status; scoring rationale; assumptions/limitations; treatment and due date; reviewer; review timestamp and version. Unknown evidence is not a pass.

Only registered synthetic EV-### items with valid paths, SHA-256, source ownership, timestamp/coverage, classification, snapshot and synthetic_data=true are treated as verified. Cite BASE-20260930 separately from REM-20261015 and RET-20261030. Do not silently revise baseline; any changed rating is a new dated record. Interview notes are simulated, never represented as actual interviews. Risk scores may use verified evidence and documented judgment, but do not claim probability calibration.

9. Worked calibration examples — illustrative, not assessed findings

Scenario	Inherent L×I	Residual treatment / uncertainty

BridgeAPI unavailable for 9 hours affecting multiple B2B customers	3×4 = 12 High	If tested recovery reduces expected duration, reassess impact with EV support; otherwise residual Unknown.
Privileged Okta account without MFA could access restricted customer metadata	4×4 = 16 High	A policy statement alone does not lower L; require enforcement evidence and retest.
CedarPay status feed delayed for 3 hours; MatchLedger reconciliation impaired	3×3 = 9 Moderate	Document vendor dependence; no inference about CedarPay internal controls.
Public storage setting could expose restricted reconciliation files	3×5 = 15 High	I=5 is a scenario assumption requiring data-sensitivity and exposure evidence; escalate catastrophic consequence.

The examples illustrate application of rubric only; they are not RSK/FND records and do not assert actual observed incidents or completed assessments.

10. Limitations, bias and override rules

• Ordinal multiplication creates apparent precision: 4×3 and 3×4 have the same score but different risk dynamics; scores are ranking aids, not quantitative expected losses.

• Band boundaries are subjective: small changes can cross thresholds; use sensitivity analysis (±1 likelihood/impact) for material decisions.

• Synthetic data, missing exposure rates, unknown threat frequency and untested controls prevent statistical calibration and can understate risk.

• The maximum-impact rule is conservative but may overemphasize a single uncertain consequence; document plausible range and confidence.

• Correlated risks (cloud region, identity provider, critical vendor) and cascading outages are not captured by independent 5×5 cells; escalate concentrations.

• Rare catastrophic risks can be under-ranked by multiplication; override/escalate any credible I=5 event, legal notification concern or customer safety issue.

• Ratings are not a substitute for financial quantification, privacy impact assessment, legal advice, threat modeling, independent audit or regulatory interpretation.

11. Governance, change control and completion gate

Versioned rubric: governance/authoritative/A-01_MapleBridge_Risk_Scoring_Rubric_v1.0.csv and companion README.md; never change v1.0 in place after use. New editions require decision record, comparison and rescoring impact assessment. Methodology document stored in governance/authoritative; future RSK records under assessment/risks. The version 1.0 document is portfolio-authored, not management-approved.

A-01 gate	Result / proof
Purpose, categories, scope, assumptions, owners	PASS — §§1–3; F-01–F-03 baseline preserved

Likelihood and impact 1–5 with concrete examples	PASS — §§5–6; 12-month horizon and five impact dimensions
5×5 scoring, bands and management response	PASS — §7; machine-readable CSV rubric
Evidence and residual scoring standard	PASS — §§4,8; F-04/F-06 provenance and no unsupported reductions
Limitations and overrides	PASS — §10; ordinal, uncertainty, catastrophic, correlated exposure
Version-controlled deliverables	PASS for local package: Word/PDF/CSV/README and SHA-256 manifest generated; Git commit pending
Risk owner/CEO formal approval	NOT CLAIMED — fictional management sign-off not performed